

Q#	NIST CSF Function	Domain
1	Govern	Information Security Policy
2	Govern	Security Contact
3	Govern	Third-Party Risk
4	Govern	Risk Management Strategy
5	Govern	Roles & Responsibilities
6	Govern	Policy Review Cadence
7	Govern	Supply Chain Risk Management
8	Govern	Regulatory Compliance Program
9	Govern	Security Governance Committee
10	Govern	Code of Conduct / Ethics
11	Identify	Asset Inventory
12	Identify	Risk Assessment
13	Identify	Data Classification
14	Identify	Data Flow Mapping
15	Identify	Fourth-Party Inventory
16	Identify	Vulnerability Management Program
17	Identify	Threat Intelligence
18	Identify	Business Environment
19	Identify	Legal & Regulatory Requirements
20	Identify	Risk Register Maintenance
21	Protect	Encryption at Rest
22	Protect	Encryption in Transit
23	Protect	Multi-Factor Authentication

24	Protect	Least Privilege Access
25	Protect	Security Awareness Training
26	Protect	Data Loss Prevention
27	Protect	Secure SDLC
28	Protect	Patch Management
29	Protect	Physical Security
30	Protect	Network Segmentation
31	Detect	Security Monitoring / SIEM
32	Detect	Anomalous Access Detection
33	Detect	Continuous Security Monitoring
34	Detect	Vulnerability Scanning
35	Detect	Penetration Testing
36	Detect	Log Retention
37	Detect	Malware / Endpoint Detection
38	Detect	Detection Process Testing
39	Detect	Unauthorized Change Detection
40	Detect	Subprocessor Monitoring
41	Respond	Incident Response Plan
42	Respond	Breach Notification SLA
43	Respond	Incident Communication Plan
44	Respond	Incident Classification Model
45	Respond	Root Cause Analysis
46	Respond	IR Plan Testing
47	Respond	Regulator/Law Enforcement Coordination

48	Respond	Containment Procedures
49	Respond	IR Plan Update Cadence
50	Respond	Post-Incident Review
51	Recover	Backup and Recovery
52	Recover	Business Continuity Testing
53	Recover	RTO/RPO Defined
54	Recover	Disaster Recovery Testing
55	Recover	Redundancy / Failover
56	Recover	Data Restoration Testing
57	Recover	Recovery Communications Plan
58	Recover	Recovery Plan Update Cadence
59	Recover	Third-Party Dependency Recovery
60	Recover	Lessons Learned Integration

Maximum Possible Score:

Question
Does your organisation have a documented information security policy?
Is there a named security contact or CISO equivalent?
Does your organisation have a documented third-party risk management policy?
Is there a board-level or executive-level risk management strategy that includes cybersecurity risk?
Are cybersecurity roles and responsibilities formally defined and assigned?
Are security policies reviewed and updated at least annually?
Does your organisation have a formal supply chain / fourth-party risk management process?
Does your organisation maintain a program to track applicable regulatory and compliance obligations (e.g., PCI DSS, GDPR, CCPA)?
Is there a governance body (e.g., security steering committee) that oversees risk decisions?
Do employees and contractors sign an acceptable use / code of conduct policy?
Do you maintain an asset inventory of systems that process our data?
Have you conducted a risk assessment in the last 12 months?
Do you classify data based on sensitivity (e.g., public, internal, confidential, restricted)?
Do you maintain data flow diagrams showing how our data moves through your systems?
Do you maintain an inventory of your own subcontractors/fourth parties with access to our data?
Do you have a documented vulnerability management program?
Do you consume threat intelligence feeds relevant to your industry?
Have you identified which of your services are critical to supporting our business relationship?
Have you identified all legal, regulatory, and contractual security requirements applicable to the services you provide us?
Do you maintain a risk register that is reviewed by leadership?
Is data encrypted at rest using AES-256 or equivalent?
Is data encrypted in transit using TLS 1.2 or higher?
Do you enforce MFA for all privileged access?

Is access to our data restricted to named individuals on a least-privilege basis?
Do you conduct security awareness training at least annually?
Do you have data loss prevention (DLP) controls in place?
Do you follow a secure software development lifecycle (SSDLC), including code review and static analysis?
Do you have a documented patch management process with defined SLAs?
Are data center / office facilities protected by physical access controls?
Is your network segmented to isolate systems that process our data?
Do you have a SIEM or equivalent log monitoring capability?
Do you have a process for detecting anomalous access to customer data?
Do you continuously monitor for security misconfigurations across your environment?
Do you perform regular vulnerability scanning of systems that process our data?
Do you conduct third-party penetration testing at least annually?
Are security logs retained for at least 12 months?
Do you have endpoint detection and response (EDR) or antivirus deployed on all relevant systems?
Are your detection processes tested through tabletop exercises or red team engagements?
Do you have controls to detect unauthorized configuration changes?
Do you monitor the security posture of your own subprocessors?
Do you have a documented incident response plan?
Are you required to notify us of a breach within 72 hours?
Do you have a defined communication plan for notifying affected customers during an incident?
Do you use a defined severity/classification model to triage incidents?
Do you perform root cause analysis after security incidents?
Has your incident response plan been tested (tabletop or live) in the last 12 months?
Do you have a documented process for coordinating with law enforcement or regulators when required?

Do you have documented containment and eradication procedures for active incidents?
Is your incident response plan reviewed and updated at least annually?
Do you conduct post-incident reviews / lessons-learned sessions after major incidents?
Do you have tested backup and recovery procedures?
Have you conducted a business continuity test in the last 24 months?
Have you defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) for services provided to us?
Do you perform disaster recovery (DR) testing at least annually?
Do your critical systems have redundancy or failover capability across multiple regions/data centers?
Do you periodically test the restoration of backups to confirm data integrity?
Do you have a communications plan to notify customers during extended outages?
Is your business continuity / disaster recovery plan reviewed and updated at least annually?
Have you assessed recovery dependencies on your own critical vendors/subprocessors?
Are lessons learned from recovery events incorporated into future BC/DR planning?

core = (Sum of Risk Weight x Score Multiplier) / Maximum Pos

Response Options	Risk Weight
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	3

Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1

Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	1

ssible Score x 100

101

Q#	NIST CSF Function	Domain
1	Govern	Information Security Policy
2	Govern	Security Contact
3	Govern	Third-Party Risk
4	Govern	Risk Management Strategy
5	Govern	Roles & Responsibilities
6	Identify	Asset Inventory
7	Identify	Risk Assessment
8	Identify	Data Classification
9	Identify	Data Flow Mapping
10	Identify	Fourth-Party Inventory
11	Protect	Encryption at Rest
12	Protect	Encryption in Transit
13	Protect	Multi-Factor Authentication
14	Protect	Least Privilege Access
15	Protect	Security Awareness Training
16	Detect	Security Monitoring / SIEM
17	Detect	Anomalous Access Detection
18	Detect	Continuous Security Monitoring
19	Detect	Vulnerability Scanning
20	Detect	Penetration Testing
21	Respond	Incident Response Plan
22	Respond	Breach Notification SLA
23	Respond	Incident Communication Plan
24	Respond	Incident Classification Model

25	Respond	Root Cause Analysis
26	Recover	Backup and Recovery
27	Recover	Business Continuity Testing
28	Recover	RTO/RPO Defined
29	Recover	Disaster Recovery Testing
30	Recover	Redundancy / Failover

Maximum Possible Score:

Question
Does your organisation have a documented information security policy?
Is there a named security contact or CISO equivalent?
Does your organisation have a documented third-party risk management policy?
Is there a board-level or executive-level risk management strategy that includes cybersecurity risk?
Are cybersecurity roles and responsibilities formally defined and assigned?
Do you maintain an asset inventory of systems that process our data?
Have you conducted a risk assessment in the last 12 months?
Do you classify data based on sensitivity (e.g., public, internal, confidential, restricted)?
Do you maintain data flow diagrams showing how our data moves through your systems?
Do you maintain an inventory of your own subcontractors/fourth parties with access to our data?
Is data encrypted at rest using AES-256 or equivalent?
Is data encrypted in transit using TLS 1.2 or higher?
Do you enforce MFA for all privileged access?
Is access to our data restricted to named individuals on a least-privilege basis?
Do you conduct security awareness training at least annually?
Do you have a SIEM or equivalent log monitoring capability?
Do you have a process for detecting anomalous access to customer data?
Do you continuously monitor for security misconfigurations across your environment?
Do you perform regular vulnerability scanning of systems that process our data?
Do you conduct third-party penetration testing at least annually?
Do you have a documented incident response plan?
Are you required to notify us of a breach within 72 hours?
Do you have a defined communication plan for notifying affected customers during an incident?
Do you use a defined severity/classification model to triage incidents?

Do you perform root cause analysis after security incidents?
--

Do you have tested backup and recovery procedures?
--

Have you conducted a business continuity test in the last 24 months?
--

Have you defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) for services provided to us?
--

Do you perform disaster recovery (DR) testing at least annually?
--

Do your critical systems have redundancy or failover capability across multiple regions/data centers?

Vendor Security Score = (Sum of Risk Weight x Score Multipl

Response Options	Risk Weight
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1

Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2

ier) / Maximum Possible Score x 100 **59**

Q#	NIST CSF Function	Domain
1	Govern	Information Security Policy
2	Govern	Security Contact
3	Identify	Asset Inventory
4	Identify	Risk Assessment
5	Protect	Encryption at Rest
6	Protect	Encryption in Transit
7	Protect	Multi-Factor Authentication
8	Protect	Least Privilege Access
9	Protect	Security Awareness Training
10	Detect	Security Monitoring / SIEM
11	Detect	Anomalous Access Detection
12	Respond	Incident Response Plan
13	Respond	Breach Notification SLA
14	Recover	Backup and Recovery
15	Recover	Business Continuity Testing

Maximum Possible Score:

Question
Does your organisation have a documented information security policy?
Is there a named security contact or CISO equivalent?
Do you maintain an asset inventory of systems that process our data?
Have you conducted a risk assessment in the last 12 months?
Is data encrypted at rest using AES-256 or equivalent?
Is data encrypted in transit using TLS 1.2 or higher?
Do you enforce MFA for all privileged access?
Is access to our data restricted to named individuals on a least-privilege basis?
Do you conduct security awareness training at least annually?
Do you have a SIEM or equivalent log monitoring capability?
Do you have a process for detecting anomalous access to customer data?
Do you have a documented incident response plan?
Are you required to notify us of a breach within 72 hours?
Do you have tested backup and recovery procedures?
Have you conducted a business continuity test in the last 24 months?

Vendor Security Score = (Sum of Risk Weight x Score Multiplier) / Maximum Pos

Response Options	Risk Weight
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	1
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	3
Yes / Partial / No / N/A	2
Yes / Partial / No / N/A	1

ossible Score x 100

32

Response	Score Multiplier	Interpretation
Yes	1	Low risk — control fully in place
Partial	0.5	Medium risk — control partially in place or in progress
No	0	High risk — control not in place
N/A	1	Excluded from scoring — question not applicable to this vendor

Scoring Formula

1. *Raw Score (per question) = Risk Weight x Score Multiplier*
 2. *Total Raw Score = Sum of all Raw Scores across the questionnaire*
 3. *Maximum Possible Score = Sum of all Risk Weights (see bottom of each question)*
 4. *Vendor Security Score = (Total Raw Score / Maximum Possible Score) x 100*
- N/A responses count toward Maximum Possible Score at full weight (multiplier 1.0) s*

o they neither help nor hurt the vendor's score.

Vendor Security Score	Risk Rating
0-49	Critical
50-69	High
70-84	Medium
85-100	Low

Required Action Summary
CISO sign-off required to onboard; existing vendors remediate within 30 days; escalate to Legal/Procurement
GRC Analyst sign-off + compensating controls to onboard; remediate within 90 days; monthly check-ins
Standard onboarding with documented findings; remediate within 180 days
Standard onboarding, no additional conditions; findings logged for awareness only